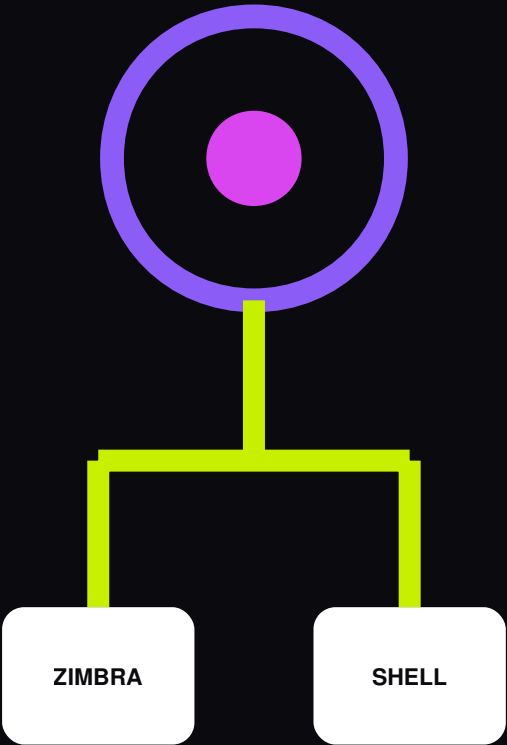


ZIMBRA SNMP SHELL INJECTION

Detects the confirmed Zimbra swatchdog-to-shell exploitation boundary using parent lineage, SNMP syntax, service markers, and shell metacharacters.

PRODUCTION CANDIDATE

CONFIDENCE: HIGH



EVIDENCE BEFORE ALERTING

REPORT DATE	STATUS
2 October 2026	Untested implementation sketch
PRIMARY PLATFORM	OPERATIONAL VALUE
Microsoft Defender XDR	10.0 / 10



EXECUTIVE ASSESSMENT

Decision, confidence and evidence boundary.

ASSESSMENT

OPERATIONAL VALUE

10.0

Detects the confirmed Zimbra swatchdog-to-shell exploitation boundary using parent lineage, SNMP syntax, service markers, and shell metacharacters.

STATUS

Production candidate

Untested implementation sketch; Confidence Medium.

1primary table

0joins

0secondary rules

2validation gates

Evidence boundary

A result confirms shell-mediated command execution through the documented Zimbra SNMP injection boundary. It does not prove webshell deployment, persistence, privilege escalation, collection, exfiltration, or actor attribution.



BEHAVIOR AND EVIDENCE

Observed facts separated from analytical scope.

MECHANICS

Source-supported fact

- 1 Microsoft investigated confirmed compromises involving unauthenticated command injection in Zimbra SNMP notification processing.
- 2 The documented boundary is a Unix shell launched by Perl running a generated .swatchdog_script and carrying snmptrap command grammar.
- 3 Microsoft states that a query match confirms shell-mediated command execution; nested payload outcomes require separate evidence.

Detection hypothesis

If an attacker exploits CVE-2026-73570, endpoint telemetry should expose the documented swatchdog-to-shell lineage and SNMP injection grammar. Distinction relies on the combined boundary, asset role, and approved-change context.

Unconfirmed elements

A result confirms shell-mediated command execution through the documented Zimbra SNMP injection boundary. It does not prove webshell deployment, persistence, privilege escalation, collection, exfiltration, or actor attribution.

Logic: Behavioral process lineage and exploit grammar **ATT&CK:** T1190 / T1059.004



TELEMETRY CONTRACT

Collection prerequisites and field reliability.

TELEMETRY

REQUIRED

Microsoft Defender for Endpoint on Linux with process creation telemetry and complete current/parent command lines on every Zimbra node.

OPTIONAL ENRICHMENT

Zimbra asset and version inventory, zimbra-snmp package state, Defender alerts, file/network events, change records, and adjacent host timeline.

Fields	Reliability	Use
Timestamp, DeviceId, DeviceName	Documented	Query or triage
FileName, FolderPath, ProcessCommandLine	Documented	Query or triage
AccountName, ProcessId, ProcessCreationTime	Documented	Query or triage
InitiatingProcessFileName, FolderPath	Documented	Query or triage
InitiatingProcessCommandLine, Id, CreationTime	Documented	Query or triage
SHA1, SHA256, ReportId	Documented	Query or triage
Zimbra role, version, package and change record	Environment-dependent	Query or triage

Excluded

No SMTP body, inferred nested payload outcome, actor attribution, IOC dependency, or undocumented cross-SIEM mapping is used.



PRIMARY KQL

Direct source-supported conditions with investigable output.

HUNTING

STATUS

Production candidate — Untested implementation sketch

KQL – UNTESTED

```
let lookback = 30d;
DeviceProcessEvents
| where Timestamp > ago(lookback)
| where FileName in~ ("sh", "bash", "dash")
| where InitiatingProcessFileName =~ "perl"
| where InitiatingProcessCommandLine contains ".swatchdog_script"
| extend Cmd = tolower(ProcessCommandLine)
| where Cmd contains "snmptrap"
| where Cmd matches regex @"(^|\s)-c(\s|$)"
| where Cmd matches regex @"::zmservicename\s+s\s+.*[;<>`$].*\s+\S+-mib::zmservicestatus"
| project Timestamp, DeviceId, DeviceName, AccountName, FileName, FolderPath,
    ProcessCommandLine, ProcessId, ProcessCreationTime,
    InitiatingProcessFileName, InitiatingProcessFolderPath,
    InitiatingProcessCommandLine, InitiatingProcessId,
    InitiatingProcessCreationTime, SHA1, SHA256, ReportId
| order by Timestamp desc
```

WINDOW

30 days; source-published hunt scope

THRESHOLD

None

JOIN / SEQUENCE

None

KEY

Single process event plus parent context



TRIAGE AND TUNING

Human validation before response.

WORKFLOW

1

Preserve

Retain the raw process event, current and parent command lines, process identifiers, hashes, account, timestamp, and ReportId.

2

Confirm

Identify the Zimbra node role, service owner, zimbra-snmp state, maintenance activity, and matching change record.

3

Enrich

Zimbra asset and version inventory, zimbra-snmp package state, Defender alerts, file/network events, change records, and adjacent host timeline.

4

Scope

Review adjacent process, file, network, alert, package, webroot, persistence, and host-timeline evidence.

Expected benign overlap

Approved Zimbra SNMP maintenance that deliberately embeds shell grammar is the principal expected overlap. Investigate every match before exclusions; never allowlist Perl, shells, or snmptrap globally.

Response boundary

A result confirms shell-mediated command execution through the documented Zimbra SNMP injection boundary. It does not prove webshell deployment, persistence, privilege escalation, collection, exfiltration, or actor attribution.



VALIDATION GATES

Controlled tests and cross-SIEM limits.

QUALITY CONTROL

Validation steps

1. Verify MDE for Linux onboarding and recent process telemetry on every Zimbra mailbox and MTA node.
2. Run a safe lab reproduction that reaches the boundary but performs only a non-destructive marker action.
3. Confirm current and parent command lines, process lineage, account, hashes, and ReportId are populated.
4. Exercise ordinary Zimbra service-state changes and approved SNMP administration to measure benign overlap.

Decision criteria

Success: The safe test returns one complete boundary event and ordinary Zimbra service operations do not match.

Rejection: Routine administration materially matches, or parent/current command-line fidelity is insufficient for the combined grammar.

Failure: Unonboarded host, sensor gap, command-line truncation, alternative launcher or exploit grammar, renamed shell, or expired retention.

Platform	Decision	Missing evidence
Defender XDR	Production candidate	Safe exploit-boundary validation
Splunk	No reliable implementation	Index, sourcetype, parser, sample
Chronicle	No reliable implementation	Parser and exact UDM mapping



CONCLUSION AND REFERENCES

Coverage statement and document control.

FINAL

CONCLUSION

Production candidate

Detects the confirmed Zimbra swatchdog-to-shell exploitation boundary using parent lineage, SNMP syntax, service markers, and shell metacharacters.

A result confirms shell-mediated command execution through the documented Zimbra SNMP injection boundary. It does not prove webshell deployment, persistence, privilege escalation, collection, exfiltration, or actor attribution.

MITRE ATT&CK

T1190 / T1059.004

References

1. Microsoft Security Research - CVE-2026-73570 - 30 Sep 2026
2. Microsoft Learn - DeviceProcessEvents schema
3. MITRE ATT&CK - T1190 and T1059.004

Document control

English dossier. No customer data. URLs are defanged in references.txt. HTML and rendering assets remain private.